

CONFIDENTIAL — INTERNAL USE ONLY

Bella ERP

Comprehensive Technical Documentation

GENERATED

July 2, 2026

VERSION

1.0.0

CLASSIFICATION

Internal

REGION

Kenya — KES

22

MODULES

44

PAGES

150+

ENDPOINTS

65+

COLLECTIONS

150+

COMPONENTS

Bella ERP — Comprehensive Technical Documentation

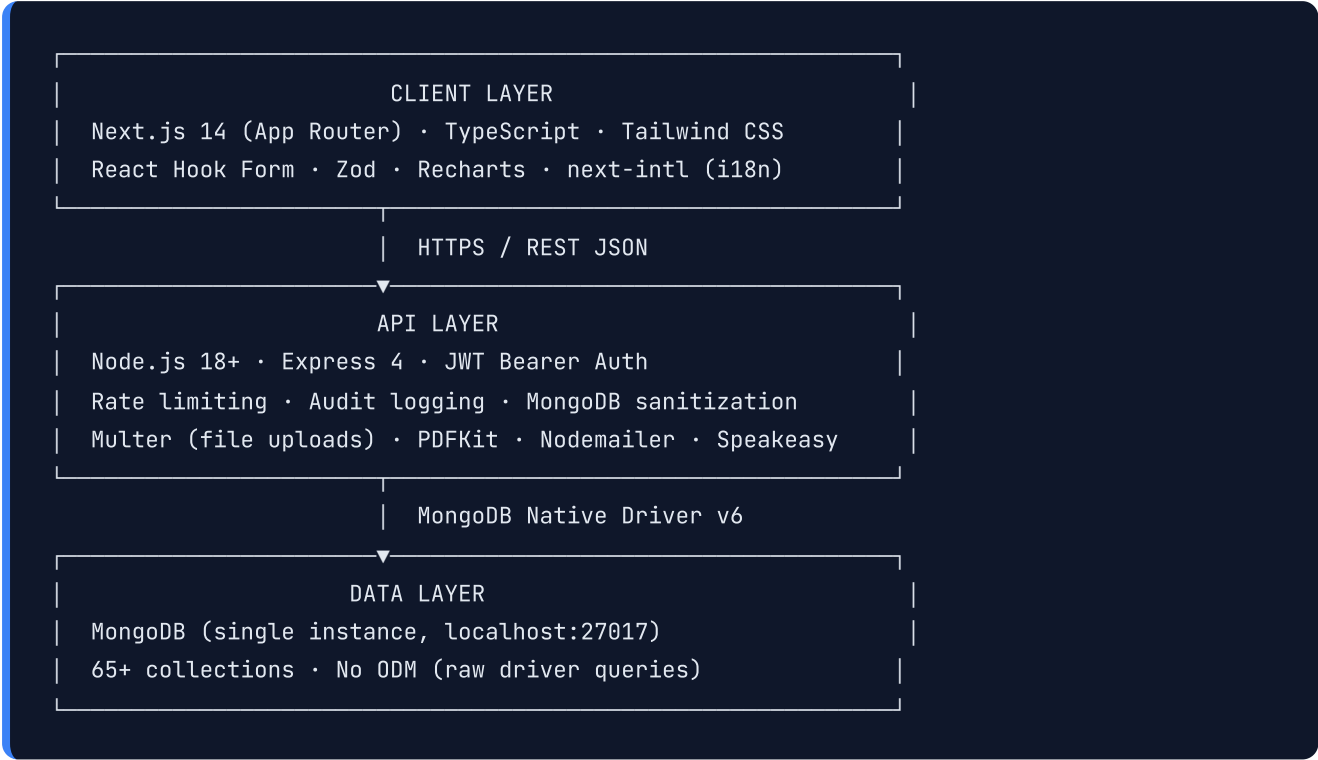
Generated: 2026-07-02
System: Bella ERP — HR / School ERP Platform
Codebase: `/home/carole/Downloads/LMS-NODE`

TABLE OF CONTENTS

- 1. [Architecture & Tech Stack](#)
 - 2. [Authentication & Authorization](#)
 - 3. [Implemented Modules](#)
 - 4. [API Endpoint Reference](#)
 - 5. [Database Collections & Schemas](#)
 - 6. [Frontend Pages & Components](#)
 - 7. [Gap Analysis — What Is Missing](#)
 - 8. [Security Assessment](#)
 - 9. [Performance & Scalability](#)
 - 10. [Recommendations & Priority Roadmap](#)
-

1. Architecture & Tech Stack

1.1 System Architecture



1.2 Tech Stack Summary

Layer	Technology	Version
Frontend Framework	Next.js (App Router)	14.2.x
Frontend Language	TypeScript	5.x
Styling	Tailwind CSS	3.4.x
UI Components	Custom + Radix UI primitives	—
Charts	Recharts	3.x
Forms	React Hook Form + Zod	7.x / 3.x
HTTP Client	Axios	1.7.x
Toasts	Sonner	1.5.x
i18n	next-intl	3.15.x
Icons	Lucide React	0.400.x

Layer	Technology	Version
Backend Framework	Node.js + Express	18+ / 4.x
Database	MongoDB (Native Driver)	6.7.x
Authentication	JWT (jsonwebtoken)	9.x
MFA	Speakeasy (TOTP) + QRCode	2.x / 1.5.x
Password Hashing	bcryptjs	2.x
File Upload	Multer	1.4.x
PDF Generation	PDFKit	0.15.x
Email	Nodemailer	8.x
Logging	Winston	3.x
Cron Jobs	node-cron	4.x
Rate Limiting	express-rate-limit	8.x
Input Sanitization	express-mongo-sanitize	2.x

1.3 Project Structure

```

LMS-NODE/
├─ backend/
│   ├─ server.js           # Entry point
│   ├─ app.js             # Express app + route registration
│   ├─ .env               # Environment config
│   └─ src/
│       ├─ configs/       # DB connection, constants
│       ├─ functions/     # Shared utilities (DB helpers, tax calc, notifiers)
│       ├─ lib/           # Logger, cron tasks, index initializer, validators
│       ├─ middleware/    # Auth, roles, scope, rate limit, audit, error handler
│       ├─ routes/        # 35 route modules (each has router + functions file)
│       └─ services/      # Email service, PDF service
├─ frontend/
│   └─ src/
│       ├─ app/[locale]/  # Next.js App Router pages (44 pages)
│       ├─ features/      # 32 feature modules (Pages + Components + Hooks)
│       ├─ functions/     # apiCallFunction, shared utils
│       ├─ configs/       # API_BASE_URL, constants
│       ├─ i18n/          # next-intl routing config
│       └─ middleware.ts   # next-intl i18n routing middleware
└─ public/

```


2. Authentication & Authorization

2.1 Authentication Flow

1. POST /api/auth/login

→ Validates email + password (bcrypt compare)

→ If MFA enabled: returns { requiresMfa: true, tempToken }

→ If MFA disabled: returns { accessToken, refreshToken, user }
2. POST /api/auth/mfa/complete (if MFA required)

→ Validates TOTP code via speakeasy

→ Returns { accessToken, refreshToken, user }
3. Every protected request:

→ Authorization: Bearer <accessToken>

→ decodeToken middleware: verifies JWT

→ getUserData middleware: loads full user from DB, attaches to req.user

2.2 JWT Token Details

Property	Value
Algorithm	HS256 (jsonwebtoken default)
Expiry	7 days (JWT_EXPIRES_IN=7d)
Secret	<code>JWT_SECRET</code> env var
Refresh Token	Stored in DB, invalidated on logout
<code>req.user</code> shape	<code>{ _id, email, role, employeeId, companyId, name, notificationsEnabled }</code>

2.3 Role-Based Access Control

Role	Access Level
<code>super_admin</code>	Full system access
<code>hr_manager</code>	All HR operations, payroll, reports
<code>department_head</code>	Team leave approval, team expenses, dept reports
<code>staff</code>	Self-service portal only (scoped to own data)

Middleware chain for protected routes:

```
decodeToken → getUserData → [allowRoles(['super_admin', 'hr_manager'])] → handler
```

Scope protection:

- `scopeBodyToSelf` — for staff, overwrites `req.body.employeeId` with their own
- `scopeParamToSelf` — blocks staff from accessing URL params for another employee

2.4 MFA (Multi-Factor Authentication)

- TOTP-based via `speakeasy`
- Setup: `POST /api/auth/mfa/setup` returns QR code URI
- Verify: `POST /api/auth/mfa/verify` validates the code and enables MFA
- Disable: `POST /api/auth/mfa/disable`
- Recovery codes: Not yet implemented

2.5 Password Management

- `POST /api/auth/forgot-password` — sends reset email
 - `POST /api/auth/reset-password` — validates token, updates password
 - `PATCH /api/auth/change-password` — authenticated self-service change
 - `POST /api/auth/accounts/:id/reset-password` — admin force-reset
-

3. Implemented Modules

3.1 Employee Management

What it does: Complete employee lifecycle management — creation, profile management, document storage, status tracking, org chart.

Key Features:

- Employee creation with full profile (personal info, job info, contact, emergency contacts, banking, contract)
- Profile updates with field-level tracking
- Employee status management (`active` , `on_leave` , `terminated` , `probation`)
- Document upload and download (contracts, IDs, certificates)
- Bulk status revert for expired leave statuses (cron job)
- Org chart generation (hierarchical, by reportsTo)
- Staff number auto-generation
- Employee search, filter (by department, status, designation)
- Paginated listing with sort

Employee Detail Tabs (frontend): Profile, Work, Leave, Payroll, Performance, Documents, Assets, Notes

3.2 HR Dashboard

What it does: Real-time KPI overview for HR managers.

Widgets:

- Headcount (total, by department)
- New hires (this month/quarter)
- Attendance rate (today)
- Pending leave requests
- Expiring contracts (next 30/60/90 days)
- Onboarding progress
- Performance concerns (overdue reviews, low-scoring employees)
- Department breakdown chart
- Open job positions summary
- Live attendance feed

- Upcoming celebrations (birthdays, work anniversaries)
 - Pending action items from inbox
 - Today's schedule
-

3.3 Recruitment Module

What it does: End-to-end applicant tracking system (ATS).

Key Features:

- Job positions board (open, filled, closed, paused)
 - Kanban board for applicant stages: `applied → shortlisted → interview_scheduled → offer_sent → hired → rejected`
 - Add applicants manually or via public portal
 - CV upload and download
 - Stage progression with approval timestamps
 - Interview scheduling (interviewer, date, time, location)
 - Offer letter generation and email delivery
 - Bulk stage patching
 - One-click hire: creates employee record, generates staff number, initializes leave balances, creates onboarding tasks
 - Applicant notes
 - HR inbox notification on new application (both portal and manual)
-

3.4 Onboarding & Offboarding

What it does: Structured task-based onboarding and offboarding checklists.

Key Features:

- Onboarding templates (reusable task sets by department)
- Auto-assign default tasks on hire
- Per-employee task list with due dates, sections, assignedDepartment
- Task completion tracking (by HR or employee self-service)
- JD (Job Description) PDF generation and serving
- HR notified when all tasks complete (inbox + bell)
- Offboarding: 10 default tasks across before_last_day / last_day / after_departure
- Offboarding task management and completion

- Frontend completion screens ("Successfully Onboarded / Offboarded")
 - Staff portal shows their own onboarding/offboarding checklists
-

3.5 Leave Management

What it does: Full leave lifecycle including balances, requests, approval, calendar, and analytics.

Key Features:

- Leave types: `annual`, `sick`, `maternity`, `paternity`, `unpaid`, `emergency`
 - Leave balance tracking per employee per type
 - Balance adjustment by HR
 - Leave request creation (HR-side and staff portal)
 - Approval / rejection / revocation workflow
 - Dispute resolution
 - Leave calendar view (by month)
 - Conflict detection (overlapping requests)
 - Today's absences widget
 - Upcoming leaves list
 - Leave export to CSV and PDF
 - Leave policies management
 - HR inbox action item on new request
 - Staff notified on approval/rejection (bell)
 - Department head can approve their team's leave
-

3.6 Attendance & Time Tracking

What it does: Daily attendance recording, clock-in/out, timesheets, shifts, and absence alerts.

Key Features:

- Clock-in / clock-out (with break start/break end)
- Today's status widget (clocked in, on break, clocked out)
- Manual attendance marking by HR
- Bulk import via CSV
- Monthly attendance grid (color-coded by status)
- Absence alerts (employees absent without leave record)
- Team status card (who's in, who's out today)

- Weekly timesheets (create, save, submit, approve, reject)
 - Shifts management (create shifts, assign employees)
 - Shift applications (open shifts employees can apply for)
 - Attendance reports
 - Staff portal: My Attendance, Timesheets, My Shifts tabs
-

3.7 Payroll Module

What it does: Multi-cycle payroll processing with Kenyan tax calculations, payslip generation, and disbursement tracking.

Key Features:

- Payroll cycles (open → review → locked → closed)
 - Bulk payroll generation per cycle
 - Per-employee payroll computation:
 - Basic pay from job group
 - Fixed allowances (housing, transport, etc.)
 - Deductions (loans, advances, etc.)
 - Kenyan statutory deductions: PAYE (progressive tax bands), NSSF, SHA (NHIF successor)
 - Net pay calculation
 - Exception tracking (missing gross pay, bank details, etc.)
 - "Fix Issues" link before approving employees with errors
 - Approve individual employees within a cycle
 - Lock and close cycles
 - Bank disbursement file export (CSV)
 - Payslip PDF generation and download
 - Employee payslip history
 - Payroll concepts (recurring pay components)
 - Employee compensation management (add/update allowances per employee)
 - Payroll analytics (gross, net, deductions totals)
 - Staff portal: My Payslips tab
-

3.8 Performance Management

What it does: Goal setting, performance reviews, appraisal cycles, 360-degree feedback, and calibration.

Key Features:

- Performance goals: create, update, delete, check-ins, comments
 - Goal Kanban board (not started / in progress / completed)
 - Goal detail drawer with progress tracking
 - Appraisal cycles: create, launch, close
 - Reviews: upsert review scores and comments per employee per cycle
 - 360 feedback: give feedback, view received feedback
 - Calibration tab (across-cycle score normalization)
 - Performance analytics (avg scores, trend charts)
 - Performance alerts (employees below threshold, overdue reviews)
 - Staff portal: Set goals, view goals, view appraisal history
-

3.9 Training & Development

What it does: LMS-style course management with enrollment, progress tracking, and certificate generation.

Key Features:

- Course catalogue: list, create, update, delete
 - Course types: `self_paced`, `instructor_led`
 - Learning objectives checklist per course
 - Self-enrollment and HR bulk-assign to employees
 - Progress tracking (% complete, objectives toggled)
 - Course start / completion tracking
 - Certificate PDF generation (landscape A4, with name, course, date)
 - Team training view for managers
 - HR assignment sends bell notification to each enrolled employee
 - Staff portal: Training tab with enroll/start/continue
-

3.10 Awards & Recognition

What it does: Employee awards, peer kudos, recognition programs, leaderboard.

Key Features:

- Award types (templates with category, repeat interval, schedule)
- Grant individual awards to employees

- Bulk grant same award to multiple employees
 - Revoke awards
 - Award stats (by type, department, top recipients)
 - Upcoming scheduled awards (within 60 days)
 - Schedule advancement after granting
 - Kudos (peer-to-peer recognition):
 - Send kudos to one or multiple recipients
 - Link to company values
 - GIF support
 - Visibility (public/private)
 - Points system
 - Reactions and comments on kudos
 - Daily kudos limit enforcement
 - Leaderboard (by month / quarter / year, by department)
 - My Rank widget
 - Recognition settings (points, limits, minimum message length)
 - Company values management (create, reorder, emoji/color)
 - Award programs: create programs, accept nominations, select winner
 - Nomination submission by any user
 - Winner announcement posted to community feed
 - Bell notifications: on award grant, on kudos received
-

3.11 Expense Claims

What it does: Employee expense claim submission, approval, dispute, and reimbursement tracking.

Key Features:

- Three expense types: `regular`, `per_diem`, `mileage`
- Per-diem: auto-calculate from destination rates and days
- Mileage: auto-calculate from distance and rate per km
- Receipt file upload
- Policy violation detection (per-category limits)
- Claim status: `draft` → `submitted` → `approved` / `rejected` → `disputed` → `reimbursed`
- HR and manager notified on submission (inbox + bell)
- Employee notified on approval, rejection, reimbursement (bell)
- HR dispute inbox item on dispute submission

- HR cannot edit staff claims (removed)
 - Rejection via modal (not browser prompt)
 - Dispute flow: employee can dispute rejected claims, HR re-reviews
 - Expense analytics (by category, month, department, top spenders)
 - Expense policy management (category limits, per-diem rates, mileage rate)
 - CSV export
 - Mark as reimbursed
-

3.12 Projects & Tasks

What it does: Project management with team assignment, time tracking, budget, and task management.

Key Features: Projects:

- Create, update, delete projects
- Project detail tabs: Overview, Team, Time Tracking, Budget, Expenses
- Team member management (add/remove)
- Time entry logging
- Project budget tracking
- Project expense logging

Tasks:

- Create tasks with assignees, priority, due date, type
 - Task statuses: not_started / in_progress / review / completed
 - Subtask support
 - Task comments
 - Task templates (reusable task sets with trigger events and due offsets)
 - Team task view and individual task list
 - Task analytics (by status, priority, assignee)
 - Employee task load overview
 - CSV export
 - Staff portal: My Tasks tab (tasks assigned to me)
-

3.13 Communication & Announcements

What it does: Company-wide communication hub — feed, announcements, 1:1 meetings, communities, trust channel.

Key Features:

- Company feed (posts, reactions, comments)
 - Community/group creation, join, leave
 - Community-specific feeds
 - Announcements: create, publish, target by department or all-staff
 - Announcement read-tracking per employee
 - Staff portal announcements view
 - 1:1 meeting series management
 - Meeting notes (create, update, view per series)
 - Upcoming celebrations (birthdays/anniversaries)
 - Trust channel: anonymous report submission (public, no auth)
 - Trust report tracking code for status check
 - Admin view of trust reports (protected)
 - Clap reactions on posts
 - Communication settings (who can post, channels enabled)
-

3.14 IT Asset Management

What it does: Device and software inventory with assignment tracking and request management.

Key Features:

- Device inventory (laptop, computer, mobile, monitor, storage, etc.)
 - Device details: brand, model, serial number, condition, asset tag
 - Assign/unassign devices to employees
 - Device summary stats (total, assigned, unassigned, in-repair)
 - Expiring assets detection
 - Software app inventory
 - Software assignment and revocation
 - IT request management (create, update, resolve)
 - Employee profile Assets tab shows assigned devices
 - IT requests tracking
-

3.15 Finance & Spending

What it does: Corporate card management, invoice tracking, procurement (purchase requests).

Key Features:

- Corporate card management (create, update, list)
 - Card transaction logging
 - Invoice management (accounts_payable / accounts_receivable)
 - Invoice approval/rejection/mark-paid workflow
 - Bell notification to submitter on invoice payment
 - Purchase requests (create, approve, reject)
 - Bell notification to requester on approval/rejection
 - Financial workspace: compensation by job group, cost centers, workforce history, trends
 - Spending analytics page
-

3.16 Notifications & Inbox

What it does: Two-layer notification system — bell notifications (quick alerts) and inbox (actionable items).

Bell Notifications:

- Per-user, stored in `notifications` collection
- Fields: `recipientId`, `userId`, `title`, `body`, `subtitle`, `type`, `isRead`, `read`, `navigateTo`, `link`
- `notifyUser(userId, payload)` — direct to user ID
- `notifyEmployee(employeeId, payload)` — lookup user by employeeId then notify
- `notifyByRoles(roles[], payload)` — broadcast to all users of given roles
- `notifyStaffByAudience(audience, department, payload)` — notify all/department staff

Inbox (Action Items):

- Stored in `inbox_items` collection
- Fields: `type`, `subType`, `title`, `subtitle`, `referenceId`, `referenceModel`, `requiresAction`, `isRead`, `isDismissed`, `actionTaken`
- `notifyHR(itemData)` — creates inbox item for all HR managers
- `notifyManager(employeeId, itemData)` — creates inbox item for the employee's manager
- `createInboxItem(recipientUserId, itemData)` — direct inbox item
- Bulk actions (mark all read, dismiss)
- Count badge in navigation

Modules with full notification wiring (as of documentation date): Leave, Payroll, Expenses, Awards, Kudos, Onboarding, Recruitment, Training assignment, Spending (invoices, purchase requests), Offboarding completion, Trust channel, Announcements

3.17 Reports Module

What it does: Cross-module analytics and exportable reports.

Available Reports:

Report	Details
Overview Report	Headcount, new hires, active employees
Attendance Report	Daily/monthly, rates, absences
Payroll Report	Gross/net totals, deductions by month
Leave Report	By type, by department, utilization
Recruitment Report	Applications, pipeline, time-to-hire
Onboarding Report	Completion rates, overdue tasks
Performance Report	Avg scores, goal completion, reviews
Expense Claims Report	By type, policy violations, totals
Awards Report	By type, by department, recognition activity
IT Assets Report	Device utilization, unassigned, in-repair
Spending Report	Invoices, purchase requests, card spend
CSV Export	Attendance CSV, Leave CSV

3.18 Staff Portal (Employee Self-Service)

What it does: Single-page employee self-service portal with 21 sections.

Sections:

Section	Capability
Profile	View & edit personal info, emergency contacts, banking
Notifications	Bell notification feed

Section	Capability
Inbox	Action items requiring response
Attendance	Daily records, clock-in/out widget
Timesheets	Weekly timesheet submission
Shifts	View assigned shifts, apply for open shifts
Leave	Balance cards, apply for time off, dispute
Tasks	Tasks assigned to me
Projects	Projects I'm a member of
Job Description	Role & responsibilities PDF
Payslips	Monthly payslip download
Expenses	Submit and track expense claims
Payment Methods	Bank & M-Pesa details
Training	Enroll in courses, track progress
Performance	Goals (view + set), appraisal history
Awards	Kudos received, leaderboard, certifications
Communication	Company feed, announcements, 1:1 meetings
Events	Upcoming training & team events
Documents	My documents (upload/download)
Onboarding	My onboarding checklist
Offboarding	My offboarding checklist
Terms	Company policies and agreements

3.19 Configuration & Settings

What it does: System-wide HR configuration.

Configuration Panels:

- Company settings (name, logo, address, terms PDF)
- Job groups (salary bands)

- Fixed allowances (housing, transport, etc.)
- Deductions (loan types, etc.)
- Designations
- Job description templates
- Tax configuration (PAYE bands, NSSF rates, SHA rates)
- Communication settings (channels, posting permissions)
- Scheduled events (holidays, training days)
- Recognition settings
- User account management (create, update, reset password)

3.20 Org Chart

- Hierarchical visualization of employee reporting lines
- Built from `reportsTo` field on employee records
- Interactive org chart page

3.21 Documents Module

- Company-wide document storage
- Employee-specific document upload/download
- Self-service document upload in staff portal
- Document categories (certificate, contract, ID, etc.)

3.22 Middleware Layer

Middleware	Purpose
<code>AsyncHandler</code>	Wraps async route handlers, forwards errors to Express error handler
<code>AuthMiddleware</code> (<code>decodeToken</code> + <code>getUserData</code>)	JWT decode → full user load from DB
<code>RolesMiddleware</code> (<code>allowRoles</code>)	Role-based route gating
<code>ScopeMiddleware</code> (<code>scopeBodyToSelf</code> , <code>scopeParamToSelf</code>)	Prevents staff accessing other employees' data

Middleware	Purpose
<code>AuditMiddleware</code>	Logs all POST/PUT/PATCH/DELETE to <code>audit_logs</code> collection
<code>ErrorHandler</code>	Global Express error handler with Winston logging
<code>LocaleMiddleware</code>	i18n — reads Accept-Language header, attaches locale strings to <code>req.locale</code>
<code>RateLimitMiddleware</code>	Auth: 5 req/15min; Writes: 60 req/min per IP

4. API Endpoint Reference

4.1 Authentication (/api/auth)

Method	Route	Description
POST	/api/auth/login	Login, returns JWT
POST	/api/auth/register	First-time system setup
POST	/api/auth/logout	Invalidate refresh token
POST	/api/auth/refresh	Refresh access token
POST	/api/auth/forgot-password	Send reset email
POST	/api/auth/reset-password	Reset with token
PATCH	/api/auth/change-password	Authenticated self-service change
POST	/api/auth/mfa/setup	Generate TOTP QR code
POST	/api/auth/mfa/verify	Enable MFA
POST	/api/auth/mfa/disable	Disable MFA
POST	/api/auth/mfa/complete	Complete MFA login

4.2 Employees (/api/employees)

Method	Route	Description
GET	/api/employees	List all employees (paginated, filterable)
POST	/api/employees	Create employee
GET	/api/employees/:id	Get single employee
PUT	/api/employees/:id	Update employee
PATCH	/api/employees/:id/status	Change status
DELETE	/api/employees/:id	Soft delete / terminate
POST	/api/employees/:id/documents	Upload document
GET	/api/employees/:id/documents/:filename	Download document

Method	Route	Description
GET	<code>/api/employees/org-chart</code>	Org chart hierarchy

4.3 Recruitment (`/api/hr`)

Method	Route	Description
GET	<code>/api/hr/positions</code>	List job positions
POST	<code>/api/hr/positions</code>	Create position
PUT	<code>/api/hr/positions/:id</code>	Update position
DELETE	<code>/api/hr/positions/:id</code>	Delete position
PATCH	<code>/api/hr/positions/:id/status</code>	Open/close/fill position
GET	<code>/api/hr/applicants</code>	List applicants (with filters)
POST	<code>/api/hr/applicants</code>	Add applicant
PUT	<code>/api/hr/applicants/:id</code>	Update applicant
PATCH	<code>/api/hr/applicants/:id/stage</code>	Move pipeline stage
PATCH	<code>/api/hr/applicants/bulk-stage</code>	Bulk stage update
POST	<code>/api/hr/applicants/:id/notes</code>	Add note
POST	<code>/api/hr/applicants/:id/offer</code>	Send offer letter
DELETE	<code>/api/hr/applicants/:id</code>	Delete applicant
GET	<code>/api/hr/interviews</code>	List interviews
POST	<code>/api/hr/interviews</code>	Schedule interview
PUT	<code>/api/hr/interviews/:id</code>	Update interview
DELETE	<code>/api/hr/interviews/:id</code>	Cancel interview

4.4 Leave (`/api/leave`)

Method	Route	Description
GET	<code>/api/leave/balances</code>	All employees' balances (HR)
GET	<code>/api/leave/balances/:employeeId</code>	Single employee balance

Method	Route	Description
PATCH	<code>/api/leave/balances/:employeeId</code>	Adjust balance
GET	<code>/api/leave/requests</code>	List all requests
POST	<code>/api/leave/requests</code>	Create request (HR)
GET	<code>/api/leave/requests/:id</code>	Get single request
PATCH	<code>/api/leave/requests/:id/approve</code>	Approve
PATCH	<code>/api/leave/requests/:id/reject</code>	Reject
PATCH	<code>/api/leave/requests/:id/revoke</code>	Revoke approved leave
PATCH	<code>/api/leave/requests/:id/cancel</code>	Cancel (employee)
DELETE	<code>/api/leave/requests/:id</code>	Delete draft
GET	<code>/api/leave/calendar</code>	Calendar entries
GET	<code>/api/leave/conflicts</code>	Detect overlaps
GET	<code>/api/leave/today-absences</code>	Who's absent today
GET	<code>/api/leave/upcoming</code>	Upcoming leaves
GET	<code>/api/leave/export</code>	CSV export
GET	<code>/api/leave/policies</code>	List leave policies
POST	<code>/api/leave/policies</code>	Create policy

4.5 Attendance (`/api/attendance`)

Method	Route	Description
GET	<code>/api/attendance</code>	List records (paginated)
POST	<code>/api/attendance/mark</code>	Mark attendance (HR)
POST	<code>/api/attendance/bulk-import</code>	CSV bulk import
POST	<code>/api/attendance/clock-in</code>	Employee clock in
POST	<code>/api/attendance/clock-out</code>	Employee clock out
POST	<code>/api/attendance/break-start</code>	Break start
POST	<code>/api/attendance/break-end</code>	Break end

Method	Route	Description
GET	/api/attendance/today-status	My today's status
GET	/api/attendance/my-records	My attendance history
GET	/api/attendance/team-status	Team live status
GET	/api/attendance/absence-alerts	Absence alerts
GET	/api/attendance/timesheets	All timesheets (HR)
GET	/api/attendance/timesheets/current	My current timesheet
POST	/api/attendance/timesheets	Save timesheet
PATCH	/api/attendance/timesheets/:id/submit	Submit timesheet
PATCH	/api/attendance/timesheets/:id/approve	Approve timesheet
PATCH	/api/attendance/timesheets/:id/reject	Reject timesheet
GET	/api/attendance/shifts	List shifts
POST	/api/attendance/shifts	Create shift
PUT	/api/attendance/shifts/:id	Update shift

4.6 Payroll (</api/payroll> , </api/me/payslips>)

Method	Route	Description
GET	/api/payroll	List payroll summaries
GET	/api/payroll/:employeeId	Employee payroll history
POST	/api/payroll/generate	Generate payslip
POST	/api/payroll/bulk-generate	Bulk generate for cycle
GET	/api/payroll/:id/download	Download payslip PDF
POST	/api/payroll/disburse	Record disbursement
GET	/api/payroll/cycles	List cycles
POST	/api/payroll/cycles	Create cycle
GET	/api/payroll/cycles/:id	Get cycle details
PATCH	/api/payroll/cycles/:id/status	Advance status

Method	Route	Description
GET	/api/payroll/cycles/:id/results	All results in cycle
GET	/api/payroll/cycles/:id/exceptions	Exceptions in cycle
POST	/api/payroll/cycles/:id/approve	Approve employees in cycle
POST	/api/payroll/cycles/:id/lock	Lock cycle
POST	/api/payroll/cycles/:id/close	Close cycle
GET	/api/payroll/cycles/:id/export	Export CSV
GET	/api/payroll/cycles/:id/bank-file	Bank disbursement file
GET	/api/payroll/concepts	List payroll concepts
POST	/api/payroll/concepts	Create concept
PUT	/api/payroll/concepts/:id	Update concept
DELETE	/api/payroll/concepts/:id	Delete concept
GET	/api/payroll/compensations/:employeeId	Employee compensation
POST	/api/payroll/compensations	Add compensation
PUT	/api/payroll/compensations/:id	Update compensation
DELETE	/api/payroll/compensations/:id	Remove compensation

4.7 Performance (</api/performance>)

Method	Route	Description
GET	/api/performance/employees/:id	Employee performance summary
POST	/api/performance/appraisals	Create appraisal
PUT	/api/performance/appraisals/:id	Update appraisal
GET	/api/performance/alerts	Performance alerts
GET	/api/performance/goals	List goals
POST	/api/performance/goals	Create goal
GET	/api/performance/goals/:id	Get goal
PUT	/api/performance/goals/:id	Update goal

Method	Route	Description
DELETE	<code>/api/performance/goals/:id</code>	Delete goal
POST	<code>/api/performance/goals/:id/checkin</code>	Add check-in
POST	<code>/api/performance/goals/:id/comments</code>	Add comment
GET	<code>/api/performance/cycles</code>	List review cycles
POST	<code>/api/performance/cycles</code>	Create cycle
GET	<code>/api/performance/cycles/:id</code>	Get cycle
PUT	<code>/api/performance/cycles/:id</code>	Update cycle
POST	<code>/api/performance/cycles/:id/launch</code>	Launch cycle
POST	<code>/api/performance/cycles/:id/close</code>	Close cycle
GET	<code>/api/performance/reviews</code>	List reviews
GET	<code>/api/performance/reviews/:id</code>	Get review
PUT	<code>/api/performance/reviews/:id</code>	Upsert review

4.8 Training (`/api/training`)

Method	Route	Description
GET	<code>/api/training/courses</code>	List courses
POST	<code>/api/training/courses</code>	Create course
GET	<code>/api/training/courses/:id</code>	Get course
PUT	<code>/api/training/courses/:id</code>	Update course
DELETE	<code>/api/training/courses/:id</code>	Delete course
POST	<code>/api/training/courses/:id/enroll</code>	Self-enroll
POST	<code>/api/training/courses/:id/assign</code>	Bulk assign employees
POST	<code>/api/training/courses/:id/start</code>	Start course
PATCH	<code>/api/training/enrollments/:id/objective</code>	Toggle objective
GET	<code>/api/training/my-training</code>	My enrollments
PATCH	<code>/api/training/enrollments/:id/progress</code>	Update progress

Method	Route	Description
GET	<code>/api/training/team</code>	Team training view
GET	<code>/api/training/enrollments/:id/certificate</code>	Download certificate PDF

4.9 Awards & Recognition (`/api/awards` , `/api/kudos`)

Method	Route	Description
GET	<code>/api/award-types</code>	List award types
POST	<code>/api/award-types</code>	Create award type
PUT	<code>/api/award-types/:id</code>	Update award type
DELETE	<code>/api/award-types/:id</code>	Delete award type
GET	<code>/api/employee-awards</code>	List employee awards
POST	<code>/api/employee-awards</code>	Grant award
POST	<code>/api/employee-awards/bulk</code>	Bulk grant
DELETE	<code>/api/employee-awards/:id</code>	Revoke award
GET	<code>/api/award-stats</code>	Award analytics
GET	<code>/api/upcoming-awards</code>	Due within 60 days
GET	<code>/api/kudos</code>	List kudos
POST	<code>/api/kudos</code>	Send kudos
DELETE	<code>/api/kudos/:id</code>	Delete kudos
POST	<code>/api/kudos/:id/react</code>	React to kudos
POST	<code>/api/kudos/:id/comments</code>	Comment on kudos
GET	<code>/api/leaderboard</code>	Recognition leaderboard
GET	<code>/api/my-rank</code>	My leaderboard rank
GET	<code>/api/company-values</code>	List company values
POST	<code>/api/company-values</code>	Create value
PUT	<code>/api/company-values/:id</code>	Update value
DELETE	<code>/api/company-values/:id</code>	Delete value

Method	Route	Description
POST	<code>/api/company-values/reorder</code>	Reorder values
GET	<code>/api/award-programs</code>	List programs
POST	<code>/api/award-programs</code>	Create program
POST	<code>/api/award-programs/:id/nominate</code>	Nominate employee
GET	<code>/api/award-programs/:id/nominations</code>	List nominations
POST	<code>/api/award-programs/:id/winner</code>	Select winner

4.10 Expense Claims (`/api/expenses`)

Method	Route	Description
GET	<code>/api/expenses/claims</code>	List claims
POST	<code>/api/expenses/claims</code>	Submit claim
GET	<code>/api/expenses/claims/:id</code>	Get claim
PUT	<code>/api/expenses/claims/:id</code>	Update claim
DELETE	<code>/api/expenses/claims/:id</code>	Delete draft/rejected
PATCH	<code>/api/expenses/claims/:id/approve</code>	Approve
PATCH	<code>/api/expenses/claims/:id/reject</code>	Reject
PATCH	<code>/api/expenses/claims/:id/dispute</code>	Dispute rejection
PATCH	<code>/api/expenses/claims/:id/reimburse</code>	Mark reimbursed
GET	<code>/api/expenses/claims/export</code>	CSV export
GET	<code>/api/expenses/analytics</code>	Analytics
GET	<code>/api/expenses/policy</code>	Get policy
PUT	<code>/api/expenses/policy</code>	Update policy

4.11 Staff Self-Service (`/api/me`)

Method	Route	Description
GET	<code>/api/me/profile</code>	My profile

Method	Route	Description
PUT	/api/me/profile	Update my profile
GET	/api/me/leave-balance	My leave balances
GET	/api/me/leave-requests	My leave history
POST	/api/me/leave-requests	Apply for leave
POST	/api/me/leave-requests/:id/dispute	Dispute rejection
GET	/api/me/payslips	My payslips
GET	/api/me/attendance	My attendance
GET	/api/me/onboarding	My onboarding tasks
POST	/api/me/onboarding/:taskId/complete	Complete task
GET	/api/me/documents	My documents
POST	/api/me/documents	Upload document
GET	/api/me/documents/:filename	Download document
DELETE	/api/me/documents/:filename	Delete document
GET	/api/me/performance	My performance/goals
GET	/api/me/awards	My awards and kudos
GET	/api/me/events	My events
GET	/api/me/department	Dept data (dept head)
PATCH	/api/me/department/leave/:id	Dept head approve/reject leave
GET	/api/me/notification-preference	Notification preferences

4.12 Communication ([/api/communication](#))

Method	Route	Description
GET	/api/communication/feed	Company feed
POST	/api/communication/posts	Create post
PUT	/api/communication/posts/:id	Update post
DELETE	/api/communication/posts/:id	Delete post

Method	Route	Description
POST	<code>/api/communication/posts/:id/react</code>	React to post
GET	<code>/api/communication/posts/:id/comments</code>	Get comments
POST	<code>/api/communication/posts/:id/comments</code>	Add comment
GET	<code>/api/communication/communities</code>	List communities
POST	<code>/api/communication/communities</code>	Create community
GET	<code>/api/communication/communities/:id</code>	Get community
POST	<code>/api/communication/communities/:id/join</code>	Join
POST	<code>/api/communication/communities/:id/leave</code>	Leave
GET	<code>/api/communication/communities/:id/feed</code>	Community feed
GET	<code>/api/communication/celebrations</code>	Upcoming birthdays/anniversaries
POST	<code>/api/communication/meeting-series</code>	Create meeting series
GET	<code>/api/communication/meeting-series</code>	List meeting series
GET	<code>/api/communication/meeting-series/:id/notes</code>	Get meeting notes
POST	<code>/api/communication/meeting-series/:id/notes</code>	Add note
POST	<code>/api/communication/trust</code>	Submit anonymous trust report (public)
GET	<code>/api/communication/trust/:trackingCode</code>	Check trust report status (public)
GET	<code>/api/communication/trust/admin</code>	HR admin view of trust reports

5. Database Collections & Schemas

5.1 Collection Index (65 collections)

Collection	Module	Description
<code>users</code>	Auth	User accounts with roles, credentials, MFA
<code>employees</code>	Employees	Employee profiles, contracts, contact info
<code>job_positions</code>	Recruitment	Open positions / job requisitions
<code>applicants</code>	Recruitment	Applicant records and pipeline stage
<code>interview_schedules</code>	Recruitment	Scheduled interviews
<code>onboarding_templates</code>	Onboarding	Reusable onboarding task templates
<code>onboarding_tasks</code>	Onboarding	Per-employee task assignments
<code>onboarding_details</code>	Onboarding	Onboarding metadata
<code>offboarding_tasks</code>	Offboarding	Per-employee offboarding tasks
<code>leave_requests</code>	Leave	Individual leave applications
<code>leave_balances</code>	Leave	Per-employee leave balance by type
<code>leave_policies</code>	Leave	Leave rules and accrual policies
<code>public_holidays</code>	Leave/Attendance	Official holidays
<code>attendance_records</code>	Attendance	Daily clock-in/out records
<code>attendance_settings</code>	Attendance	Work hours, grace periods
<code>timesheets</code>	Attendance	Weekly timesheet submissions
<code>shifts</code>	Attendance	Shift definitions
<code>shift_applications</code>	Attendance	Open shift applications
<code>work_schedules</code>	Attendance	Employee work schedule assignments
<code>payroll_cycles</code>	Payroll	Payroll cycle definitions
<code>payroll_results</code>	Payroll	Per-employee per-cycle computed results
<code>payroll_summaries</code>	Payroll	Payslip documents

Collection	Module	Description
disbursements	Payroll	Payment disbursement records
tax_config	Payroll/Config	PAYE bands, NSSF, SHA rates
goals	Performance	Employee performance goals
review_cycles	Performance	Performance review cycle definitions
reviews	Performance	Per-employee review scores/comments
appraisal_records	Performance	Appraisal history
training_courses	Training	Course catalogue
training_enrollments	Training	Enrollment and progress records
award_types	Awards	Award type templates
employee_awards	Awards	Granted awards
kudos	Awards	Peer recognition posts
recognition_settings	Awards	Recognition module configuration
company_values	Awards	Organizational values
award_programs	Awards	Nomination-based award programs
award_nominations	Awards	Nominations per program cycle
expense_claims	Expenses	Employee expense claim records
expense_policies	Expenses	Expense limits and rates
expenses	Expenses	General expense records
tasks	Tasks	Task definitions and assignments
task_templates	Tasks	Reusable task templates
projects	Projects	Project definitions
project_members	Projects	Project team membership
project_time_entries	Projects	Time logged against projects
project_expenses	Projects	Expenses logged against projects
announcements	Communication	Company announcements
community_posts	Communication	Feed posts

Collection	Module	Description
<code>post_comments</code>	Communication	Comments on posts
<code>communities</code>	Communication	Groups/channels
<code>trust_reports</code>	Communication	Anonymous trust/ethics reports
<code>meeting_notes</code>	Communication	1:1 meeting notes
<code>one_on_ones</code>	Communication	1:1 meeting series
<code>messages</code>	Messaging	Direct / group messages
<code>conversations</code>	Messaging	Conversation threads
<code>notifications</code>	Notifications	Bell notification records
<code>inbox_items</code>	Inbox	Action-required inbox items
<code>devices</code>	IT	IT device inventory
<code>software_apps</code>	IT	Software license inventory
<code>invoices</code>	Spending	Accounts payable/receivable invoices
<code>card_transactions</code>	Spending	Corporate card transactions
<code>purchase_requests</code>	Spending	Procurement requests
<code>staff_notes</code>	HR	Private HR notes on employees
<code>jd_templates</code>	Config	Job description templates
<code>audit_logs</code>	System	All mutating API action audit trail

5.2 Key Schema Shapes

`users` collection:

```
{
  "_id": ObjectId,
  "email": String,
  "password": String (bcrypt),
  "role": "super_admin|hr_manager|department_head|staff",
  "employeeId": ObjectId (nullable),
  "companyId": ObjectId (nullable),
  "fullName": String,
  "notificationsEnabled": Boolean,
  "mfaEnabled": Boolean,
  "mfaSecret": String,
  "refreshToken": String,
  "resetToken": String,
  "resetTokenExpiry": Date,
  "lastLogin": Date,
  "createdAt": Date
}
```

employees collection:

```
{
  "_id": ObjectId,
  "staffNumber": String,
  "fullName": String,
  "email": String,
  "phone": String,
  "department": String,
  "designation": String,
  "jobGroupId": ObjectId,
  "grossPay": Number,
  "status": "active|on_leave|terminated|probation",
  "hireDate": Date,
  "contractEndDate": Date,
  "reportsTo": ObjectId,
  "bankName": String,
  "bankAccountNumber": String,
  "nationalId": String,
  "emergencyContact": { name, phone, relationship },
  "documents": [{ filename, originalName, uploadedAt }],
  "createdAt": Date
}
```

payroll_results collection:

```
{
  "_id": ObjectId,
  "cycleId": ObjectId,
  "employeeId": ObjectId,
  "grossPay": Number,
  "allowances": [{ name, amount }],
  "deductions": { paye, nssf, sha, loan, other },
  "netPay": Number,
  "employerCost": Number,
  "status": "pending|approved|paid",
  "exceptions": [{ field, message, severity }],
  "approvedAt": Date,
  "approvedBy": ObjectId
}
```

6. Frontend Pages & Components

6.1 App Router Pages (44 pages)

Route	Page	Module
<code>/[locale]/login</code>	LoginPage	Auth
<code>/[locale]/register</code>	RegisterPage	Auth
<code>/[locale]/apply</code>	Public job application	Recruitment
<code>/[locale]/dashboard</code>	HR Dashboard	Dashboard
<code>/[locale]/employees</code>	Employee list	Employees
<code>/[locale]/employees/new</code>	Create employee	Employees
<code>/[locale]/employees/[id]</code>	Employee detail	Employees
<code>/[locale]/recruitment</code>	Recruitment ATS	Recruitment
<code>/[locale]/onboarding</code>	Onboarding list	Onboarding
<code>/[locale]/onboarding/[employeeId]</code>	Employee checklist	Onboarding
<code>/[locale]/offboarding</code>	Offboarding list	Offboarding
<code>/[locale]/offboarding/[employeeId]</code>	Employee checklist	Offboarding
<code>/[locale]/leave</code>	Leave overview	Leave
<code>/[locale]/leave-management</code>	Leave management	Leave
<code>/[locale]/attendance</code>	Attendance	Attendance
<code>/[locale]/payroll</code>	Payroll cycles	Payroll
<code>/[locale]/payroll/concepts</code>	Pay concepts	Payroll
<code>/[locale]/payroll/employees</code>	Employee payroll	Payroll
<code>/[locale]/payroll/payslips</code>	Payslip history	Payroll
<code>/[locale]/performance</code>	Performance	Performance
<code>/[locale]/training</code>	Training LMS	Training
<code>/[locale]/certifications</code>	Certifications	Training

Route	Page	Module
<code>/[locale]/communications</code>	Announcements (HR)	Announcements
<code>/[locale]/communication</code>	Staff comms	Communication
<code>/[locale]/tasks</code>	Task management	Tasks
<code>/[locale]/projects</code>	Projects list	Projects
<code>/[locale]/projects/[id]</code>	Project detail	Projects
<code>/[locale]/expenses</code>	Expense claims	Expenses
<code>/[locale]/spending</code>	Finance/spending	Spending
<code>/[locale]/finance/workspace</code>	Financial workspace	Finance
<code>/[locale]/accounts</code>	User accounts	Accounts
<code>/[locale]/org-chart</code>	Org chart	OrgChart
<code>/[locale]/documents</code>	Documents	Documents
<code>/[locale]/assets-management</code>	IT assets	IT
<code>/[locale]/it-management</code>	IT management	IT
<code>/[locale]/notifications</code>	Notifications	Notifications
<code>/[locale]/inbox</code>	Inbox	Inbox
<code>/[locale]/events</code>	Events	Communication
<code>/[locale]/reports</code>	Reports	Reports
<code>/[locale]/config</code>	HR configuration	Config
<code>/[locale]/settings</code>	User settings	Settings
<code>/[locale]/staff-portal</code>	Staff portal (HR view)	Staff Portal

6.2 HR Dashboard Widgets (9 components)

AttendanceRateWidget, DepartmentBreakdownWidget, ExpiringContractsWidget, HeadcountWidget, NewHiresWidget, OnboardingProgressWidget, PendingLeaveWidget, PerformanceConcernsWidget, PositionsSummaryWidget

6.3 Employee Detail Tabs (14 component files)

ProfileTab, WorkTab, LeaveTab, PayrollTab, PerformanceTab, DocumentsTab, AssetsTab, NotesTab, EmployeeDetailTabs, EmployeeCard, EmployeeFilters, EmployeeTable, EmployeeSchema,

7. Gap Analysis — What Is Missing

7.1 Missing Modules (Standard in Production HR Systems)

Module	Priority	Notes
Succession Planning	High	Identifying and developing internal candidates for key roles — standard in Workday, SAP
Compensation Benchmarking	High	Market salary comparison, pay equity analysis — core in BambooHR, Factorial
Benefits Administration	High	Health insurance, pension enrollment, benefit elections — missing entirely
Employee Wellness Module	Medium	Mental health resources, wellness challenges, EAP links
Compliance & Policy Acknowledgements	High	Digital policy sign-off with audit trail (GDPR, labor law)
Disciplinary Management	High	Warning letters, PIPs (Performance Improvement Plans), hearing records
Grievance Management	High	Formal grievance submission and tracking
Contract Management	Medium	Contract generation from templates, e-signatures, expiry alerts
Time-Off Accrual Engine	High	Automatic balance accrual by tenure, policy rules (currently manual)
Advanced Scheduling	Medium	Roster/schedule builder with shift swapping, drag-and-drop
Multi-company / Multi-tenant	Medium	Single instance serving multiple organizations
Survey & Engagement	Medium	Pulse surveys, eNPS, engagement scoring (standard in Workday, Lattice)
HR Helpdesk / Ticketing	Medium	Employee queries with SLA tracking
Job Requisition Approval Flow	High	Multi-step approval before a position goes live
Onboarding Portal (Candidate-facing)	Medium	Pre-boarding experience before day 1

7.2 Partially Implemented Features

7.2.1 Leave Module Gaps

Note: Leave accrual (`runLeaveAccrual` at 1.75 days/month, idempotent) **IS implemented** as a backend function. Frontend trigger and scheduling should be verified.

Missing Feature	Impact
Accrual automation (cron scheduling for monthly run)	<code>runLeaveAccrual</code> exists but must be confirmed it runs automatically
Carry-forward rules and expiry	No enforcement of use-it-or-lose-it policies
Leave encashment calculation	Cannot pay out unused leave
Blackout periods (no-leave dates)	Not enforced
Minimum notice period enforcement	Leave can be applied for any start date
Comp-off leave (overtime compensation)	Missing leave type
Half-day leave	Only full-day requests
Public holiday exclusion from leave count	Unclear if implemented
Leave approval delegation	If manager is on leave, no substitute
Male vs. female-specific leave types	Paternity correctly separate, but no flexible assignment

7.2.2 Payroll Module Gaps

Missing Feature	Impact
Overtime pay calculation	Manual only
Bonus and commission processing	Not in the cycle engine
Arrears and retroactive pay	Not supported
Off-cycle / supplemental payroll	One cycle per month only
Loan repayment deduction schedule	Deductions are flat, no amortization
Pension/provident fund (beyond NSSF)	NSSF only — no private pension
Kenya-specific: Housing Levy (Affordable Housing Levy)	Not in tax config
Fringe benefits tax	Not calculated

Missing Feature	Impact
Employer P9 form generation	PAYE reconciliation form missing
P9A / P9B annual tax return	Not implemented
Pay slip email delivery	Payslips must be downloaded manually
Payroll approval workflow (multi-level)	Single-level HR approval only
Bank integration / direct payment	Bank file export only (manual upload)
Year-end processing	No annual reconciliation

7.2.3 Performance Module Gaps

Missing Feature	Impact
360-degree feedback from peers/reports	Only manager-to-employee
Self-assessment by employee	Not implemented
Weighted competency scoring	No competency framework
Performance improvement plan (PIP)	Missing
Forced ranking / bell curve	9-box calibration grid IS implemented (<code>getCalibration</code> , <code>updateCalibrationBox</code>) — frontend <code>CalibrationTab</code> exists
OKR (Objectives & Key Results) framework	Goal types not clearly OKR-structured
Continuous feedback (daily/weekly)	Check-ins exist but no formal continuous feedback loop
Review reminders and escalation	No automated reminders

7.2.4 Recruitment Module Gaps

Missing Feature	Impact
AI-powered candidate matching	Manual review only
Job posting to external boards	No integration (LinkedIn, Indeed)

Missing Feature	Impact
Automated screening questions	Not present
Assessment/test scheduling	Not present
Reference check tracking	Not tracked
Background check integration	Not tracked
Offer letter e-signature	Email only, no e-sign
Careers page builder	Public application page is basic
Requisition approval workflow	Positions can be created without approval
Time-to-hire / cost-per-hire metrics	Basic recruitment report only
Candidate portal (self-serve status check)	Not present

7.2.5 Attendance Module Gaps

Missing Feature	Impact
Geofencing / GPS check-in	Partially implemented (<code>GOOGLE_MAPS_API_KEY</code> used in <code>clockIn</code>) — needs frontend UI and configuration
Biometric integration	No fingerprint / facial recognition hooks
Overtime tracking and approval	Clock-in/out only, no overtime computation
Late arrival / early departure alerts	No threshold alerts
Work-from-home logging	No distinction from office attendance
Regularization requests (explain absence)	Not implemented
Holiday calendar integration	<code>public_holidays</code> collection exists but not enforced
Real-time attendance dashboard (live)	Team status exists but not real-time (no WebSocket)

7.2.6 Training Module Gaps

Missing Feature	Impact
SCORM / xAPI support	External course content cannot be imported

Missing Feature	Impact
Video/multimedia lesson content	Objectives checklist only
Quizzes and assessments	Not present
Course prerequisites	No sequential learning path
Learning paths / curricula	No bundles of courses
Compliance training tracking with mandatory deadlines	Basic due date only
Training budget tracking	Not in the module
Third-party LMS integration	Not present

7.2.7 Documents Module Gaps

Missing Feature	Impact
E-signature integration (DocuSign, HelloSign)	Not present
Document template generation	JD templates exist but no broader HR letter generation
Document expiry alerts	Contract expiry tracked in employee but not for documents
Document version control	Overwrite only, no history
Access control on documents	All HR can see all documents
Policy acknowledgement tracking	Not present

7.2.8 Communication Gaps

Missing Feature	Impact
Real-time messaging (WebSocket)	Messages are stored but no live push (no Socket.io)
Push notifications (browser/mobile)	Bell notifications are poll-based, not push
Email digests	No daily/weekly summary emails
Video/audio conferencing integration	No Zoom/Teams integration
Channel permissions	All communities are open

7.3 Configuration Gaps

Missing Config	Impact
SMTP not fully configurable from UI	Must edit <code>.env</code> — email settings not in admin panel
No multi-language support for UI	<code>next-intl</code> routing exists but locale strings not user-configurable
Department management not a standalone module	Departments are free-text strings, not a managed collection
Location / branch management	No concept of physical office locations
Fiscal year configuration	Month-based payroll cycles only
Working days / week configuration	<code>attendance_settings</code> collection exists but limited

8. Security Assessment

8.1 What Is In Place

Control	Implementation
Password hashing	bcrypt (rounds default ~10)
JWT authentication	Bearer token, 7-day expiry
MFA	TOTP via speakeasy
Rate limiting	Auth: 5/15min; Writes: 60/min per IP
MongoDB injection prevention	<code>express-mongo-sanitize</code>
Audit logging	All mutating requests logged with user, IP, body
Role-based access	<code>allowRoles</code> middleware per route
Scope enforcement	Staff cannot access other employees' data
Error masking	500 errors return generic message, details logged server-side
File access control	<code>/uploads</code> requires JWT

8.2 Security Gaps

Gap	Severity	Description
JWT secret in <code>.env</code>	Critical	<code>JWT_SECRET=school-erp-jwt-secret-key-2024-secure</code> — weak, predictable, must be rotated before production
No HTTPS enforcement	Critical	Backend runs HTTP on port 5000; no TLS configuration
No CORS restriction	High	<code>app.use(cors())</code> with no origin whitelist — accepts any origin
No Content Security Policy	High	No CSP headers set
File upload validation	High	Multer accepts files but no MIME type validation or virus scanning
No input length limits	Medium	Free-text fields (notes, descriptions) have no max length limits

Gap	Severity	Description
Refresh token storage	Medium	Refresh token stored in plain text in DB — should be hashed
No token rotation	Medium	Refresh tokens are reused without rotation
No account lockout	Medium	Rate limiting is per-IP, not per-account — distributed brute force not blocked
Password policy	Medium	No minimum length, complexity, or history enforcement
No RBAC for data fields	Medium	All HR roles see all employee fields including salary
No PII encryption at rest	High	National ID, bank account numbers stored as plain text
Missing security headers	Medium	No Helmet.js — missing X-Frame-Options, HSTS, X-XSS-Protection
Sensitive data in audit logs	Medium	<code>req.body</code> is logged with <code>_redact()</code> but full coverage not verified
No IP allowlisting for admin	Low	Super admin accessible from any IP
MFA recovery codes	Medium	No backup codes generated if TOTP device is lost
Session invalidation	Medium	Token revocation only on explicit logout — no forced expiry on role change

9. Performance & Scalability

9.1 Current Limitations

Issue	Impact	Severity
No database indexes defined	<code>initIndexes()</code> called but index definitions need verification — queries on <code>employeeId</code> , <code>cycleId</code> , <code>status</code> , <code>createdAt</code> will be slow at scale	High
N+1 query patterns	Several list endpoints fetch parent records in a <code>map()</code> loop (e.g. <code>enriched = await Promise.all(data.map(async c => findOne('employees' ...)))</code>)	High
No caching layer	No Redis / in-memory cache — dashboard, reports, leaderboard recalculated on every request	Medium
Single MongoDB instance	No replica set, no read scaling, no automatic failover	High
No connection pooling configuration	Default MongoDB driver pool settings	Medium
File storage on local disk	<code>uploads/</code> on the server — won't work on multi-server or cloud deployments	High
Payroll bulk generation	<code>bulkGeneratePayroll</code> runs sequentially for all employees in the cycle — will timeout for large headcounts	Medium
No pagination on some endpoints	Some endpoints fetch up to 5000 records (CSV export, analytics) without streaming	Medium
Real-time features are polling	Notifications, messages, and team status are fetched on request, not pushed	Medium
No job queue	Long-running tasks (bulk payroll, bulk email, PDF generation) run synchronously in the request thread	Medium
Frontend bundle size	No lazy loading analysis documented; 44 pages with full import	Low

9.2 Reliability Gaps

Issue	Impact
No automated backups	Data loss risk — no backup schedule configured
No health check monitoring integration	/health endpoint exists but not wired to monitoring
No graceful shutdown handling	Process kill may lose in-flight writes
Email delivery failures are silent	Nodemailer errors are caught but not retried or alerted
Cron jobs have no dead-letter handling	Failed cron jobs don't alert

10. Recommendations & Priority Roadmap

10.1 Immediate (Before Production Launch)

#	Action	Why
1	Rotate JWT secret	Current secret is too predictable; generate a 256-bit random secret
2	Add CORS origin whitelist	Replace <code>cors()</code> with <code>cors({ origin: ['https://yourapp.com'] })</code>
3	Add Helmet.js	One-line fix for 8+ security headers
4	Validate file upload MIME types	Prevent malicious file uploads via Multer <code>fileFilter</code>
5	Configure MongoDB indexes	Ensure <code>initIndexes()</code> covers all high-traffic query patterns
6	Fix payslip email delivery	Employees should receive payslips by email, not just download
7	Add password policy enforcement	Minimum 8 chars, complexity, prevent reuse of last 5 passwords
8	Deploy behind HTTPS	TLS termination via Nginx or cloud load balancer
9	Hash refresh tokens in DB	Store <code>bcrypt(refreshToken)</code> instead of plain text
10	Add Kenya Housing Levy	Affordable Housing Levy is currently a statutory deduction in Kenya

10.2 Short-Term (Next 4–8 Weeks)

#	Module	Feature
1	Leave	Auto-accrual engine (cron job: add <code>X days/month</code> per policy)
2	Leave	Carry-forward rules with expiry dates
3	Payroll	P9 form generation for KRA compliance
4	Payroll	Email payslips to employees on cycle close
5	Payroll	Employer contribution breakdown in payslip
6	Attendance	Overtime calculation and approval

#	Module	Feature
7	Performance	Employee self-assessment form
8	Performance	360-degree peer feedback
9	Recruitment	Multi-step job requisition approval
10	Notifications	Browser push notifications (Web Push API)
11	Documents	Document expiry alerts (contracts, IDs)
12	Disciplinary	Warning letters and disciplinary records module
13	Infrastructure	Move file storage to S3-compatible object storage
14	Infrastructure	Add Redis caching for dashboard and reports

10.3 Medium-Term (2–4 Months)

#	Module	Feature
1	Benefits	Benefits enrollment module (health, pension, group life)
2	Succession	Succession planning with talent pool identification
3	Training	SCORM content support, quizzes, learning paths
4	Survey	Pulse survey and eNPS module
5	Payroll	Off-cycle / supplemental payroll run
6	Payroll	Loan amortization schedule with auto-deductions
7	Communication	WebSocket-based real-time messaging and notifications
8	Compliance	Digital policy acknowledgement with audit trail
9	Contract	Contract template generation and e-signature integration
10	Recruitment	Integration with LinkedIn/job boards for posting
11	Reports	Custom report builder (drag-and-drop field selection)
12	Multi-tenancy	Company isolation for SaaS deployment

10.4 Architecture Improvements

Improvement	Recommendation
Queue system	Add BullMQ (Redis-backed) for async processing of payroll, emails, PDF generation
MongoDB replica set	At minimum 3-node replica set for production reliability
Object storage	AWS S3 or MinIO for file uploads — decouple from server disk
API versioning	Add <code>/api/v1/</code> prefix to allow non-breaking future changes
Database ODM	Consider Mongoose for schema validation at the DB layer (currently none)
Monitoring	Integrate Sentry for error tracking; Datadog or Grafana for metrics
CI/CD	Add GitHub Actions pipeline with lint, test, and deploy stages
Testing	Zero automated tests currently — add Jest unit tests and Supertest API integration tests
Environment management	Use separate <code>.env.development</code> , <code>.env.staging</code> , <code>.env.production</code> — never commit secrets
Docker	Add <code>docker-compose.yml</code> for consistent dev environments

10.5 Code Quality Recommendations

Issue	Recommendation
Inconsistent notification field names (<code>message</code> vs <code>body</code> , <code>read</code> vs <code>isRead</code>)	Fixed in July 2026 — enforce via a single <code>notifyUser</code> helper (done)
N+1 query patterns in list endpoints	Replace <code>map + findOne</code> with <code>\$lookup</code> aggregations
No input validation beyond <code>validateRequiredFields</code>	Add Zod or Joi schema validation on all POST/PUT body fields
No automated tests	Start with API integration tests covering auth, leave, payroll cycles
Magic strings for roles/statuses	Extract to constants file (<code>ROLES.HR_MANAGER</code> , <code>LEAVE_STATUS.APPROVED</code>)
Direct <code>global.dbo.collection()</code> calls mixed with helper functions	Standardize to one pattern (either always use helpers or always use raw)

Issue	Recommendation
<code>JWT_SECRET</code> in <code>.env</code> committed to repo	Add <code>.env</code> to <code>.gitignore</code> , use <code>.env.example</code> with placeholder values

Documentation generated from codebase analysis as of 2026-07-02. Reflects the state of all implemented and audited modules.